UNIVERSITÀ DEGLI STUDI DI PADOVA

DIPARTIMENTO DI INGEGNERIA DELL'INFORMAZIONE

Web Applications A.Y. 2025-2026

Homework 1 – Server-side Design and Development

Master Degree in Computer Engineering
Master Degree in Cybersecurity
Master Degree in ICT for Internet and Multimedia

Deadline: 24 April, 2026

Group Acronym	WASP	
Last Name	**First Name**	**Badge Number**
Bardhi	Rajmonda	2071810
Karriqi	Meviola	2183853
Perin	Alessandro	2203653
Smirnov	Danil	2142049
Masiero	Giacomo	2130974

1 Objectives

FinTrack is a personal finance management web application designed to help individuals monitor, analyse, and plan their financial situation through a single, unified platform.

The primary objective of the system is to give users full visibility over their financial state. Many people manage money across multiple accounts or wallets without a consolidated view of their overall position. FinTrack addresses this by aggregating all wallets and transactions into a single dashboard that shows total equity, year-to-date expenses, and year-to-date savings at a glance.

A second objective is to support forward-looking financial planning. Knowing the current balance is not enough if a user also wants to understand how their finances may evolve over time. FinTrack therefore provides a forecasting module that projects income, expenses, PAC contributions, and net balance month by month over a 24-month horizon under three scenarios: optimistic, conservative, and stress test. This allows users to anticipate potential shortfalls and make informed decisions before problems arise.

A third objective is to encourage disciplined long-term saving through PAC plans. A PAC (Piano di Accumulo Capitale) is a recurring investment plan in which a fixed amount is contributed each month toward a defined target. FinTrack lets users create, track, and adjust these plans, and integrates them directly into the forecasting logic so that their impact on future balances is always visible.

Finally, the system aims to be accessible even to users who are not yet registered. A public guest area provides three standalone financial calculators — loan amortisation, compound interest, and budget analysis — so that anyone can use the core analytical tools without creating an account. This lowers the barrier to entry and demonstrates the value of the platform before a commitment is made.

2 Main Functionalities

- *Registration and Login:* New users must register by providing their name, surname, email address, and password. Passwords are hashed using PBKDF2 (pure Java `javax.crypto`) before storage and are never persisted in plain text. Once registered, users can log in to authenticate their session and access all protected features. Failed login attempts return an error message without exposing internal details.
- *Guest Access:* Users who do not wish to create an account can continue as guests. A session-scoped UUID token is generated and persisted in the `report_sessions` table, allowing guests to generate one-off financial reports without registration.
- *Wallet Management:* Authenticated users can create, view, edit, and delete financial wallets. Each wallet has a name, type (cash, bank account, credit card, or investment), and a 3-letter currency code. All wallets under one account must use the same currency. Deletion is rejected if the wallet contains linked transactions.
- *Transaction Tracking:* Users can record income and expense transactions within their wallets. Transactions are managed through a REST/JSON API, allowing interactive creation, editing, and deletion without full page reloads. Positive amounts are treated as income and negative amounts as expenses, resolved automatically at the service layer. Amounts are stored as absolute values with two decimal places.
- *PAC (DCA) Investment Plans:* Users can create and manage Dollar Cost Averaging investment plans. Each plan specifies an asset name, a monthly contribution amount, a target amount, and a start date. Plans can be activated or deactivated and are factored into the forecasting engine.
- *Recurring Expenses:* Users can define recurring financial obligations with configurable periodicity (monthly, quarterly, or yearly). Active recurring expenses are normalized to monthly equivalents and included in forecast projections.
- *Financial Forecasting:* The application provides a 24-month net worth projection engine accessible via a REST/JSON API. Users select one of three scenarios:
  - **Optimistic:** income increased by 10%, expenses unchanged.

- **Conservative:** income unchanged, expenses subject to 3% compounding monthly inflation.
- **Stress Test:** income reduced by 20%, with a one-off expense shock of 3× the average monthly expense at month 6.

Projections are computed from current wallet balances, the 3-month average of income and expenses, active recurring expenses, and active PAC contributions. Results are stored as JSONB in the database for later retrieval.

- *Dashboard:* After logging in, users are redirected to a dashboard that serves as the central hub for navigating wallets, transactions, PAC plans, and forecasts.

3 Data Logic Layer

3.1 Entity-Relationship Schema

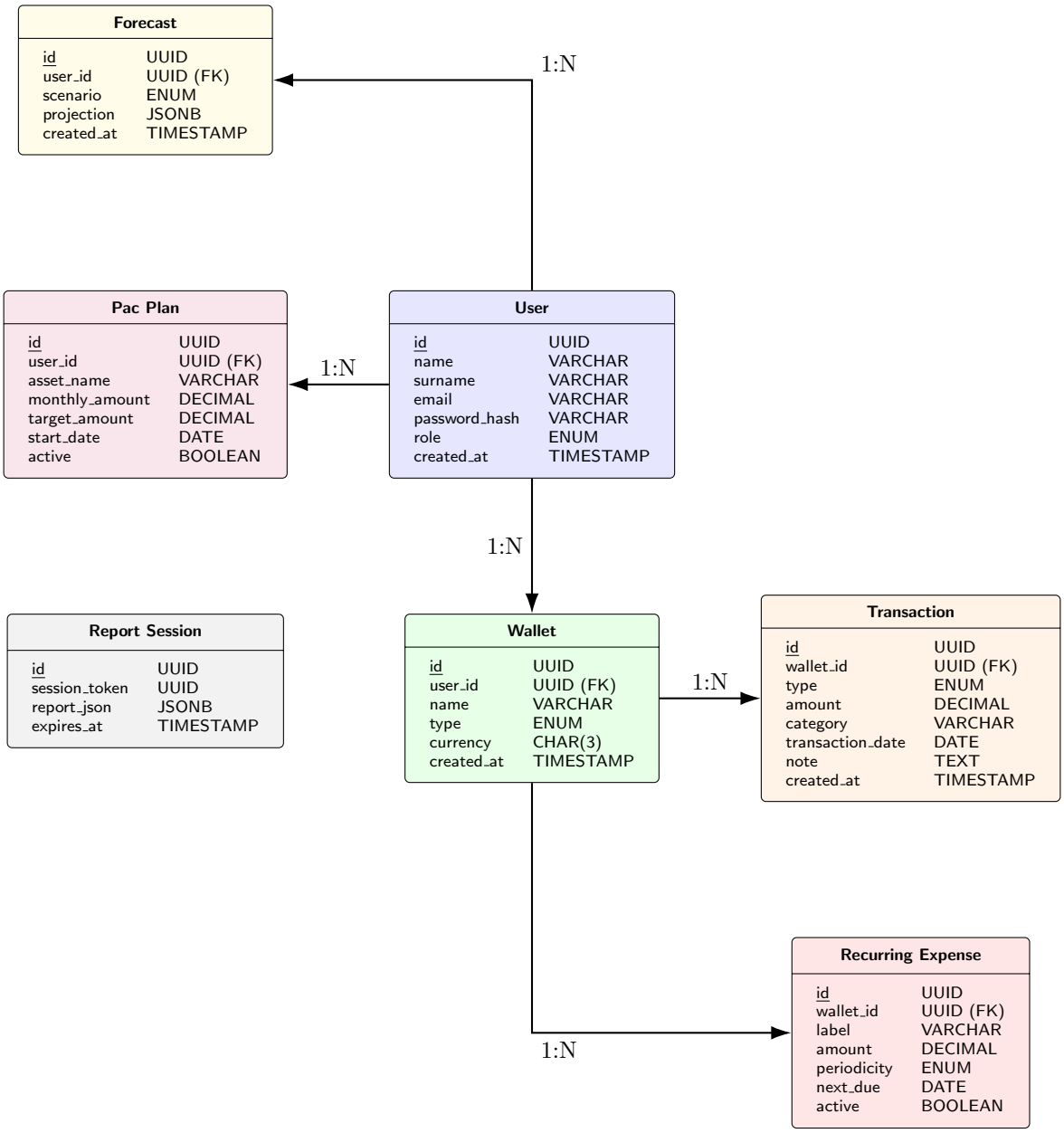


Figure 1: Entity-Relationship Schema

The application's data is persisted in a relational database mapping its core entities. The ER schema models the users, their financial wallets, atomic exchanges (transactions), recurring events, saving plans, analytical forecasts, and temporary sessions.

The primary attributes and relationships of each entity are defined as follows:

- **User**: Represents the central entity, storing personal details, authentication credentials (via `password_hash`),

and the assigned role (e.g., REGISTERED or GUEST_SESSION).

- **Wallet**: A one-to-many relationship exists between User and Wallet since a user can possess multiple wallets (e.g., Cash, Bank Account). Each wallet maintains a strict user_id reference (with cascading deletion) and stores the currency used.
- **Transaction**: Linked to a specific Wallet (wallet_id), representing an atomic financial entry (INCOME or EXPENSE). It stores crucial financial data such as amount, category, transaction_date, and an optional note.
- **Recurring Expense**: Also associated with a Wallet, this entity defines scheduled cash outflows, keeping track of the periodicity (e.g., Monthly), the next_due date, and an active flag for toggling state without deletion.
- **Pac Plan**: Defines periodic investment (PAC) goals mapped directly to a User. It captures the asset_name, monthly_amount, and the overall target_amount.
- **Forecast**: A purely analytical entity connected to a User, storing a chosen scenario (e.g., OPTIMISTIC) and the resultant JSON structural breakdown of the projection_json.
- **Report Session**: A transient entity used for temporary guest access, managing a session_token, the embedded report_json, and an expires_at timestamp.

3.2 Other Information

In addition to the standard conceptual schema, the Data Logic Layer incorporates several implementation-specific features at the database level to ensure data integrity and operational safety:

- **Primary Keys and Security**: All entities utilize universally unique identifiers (UUIDv4) as primary keys instead of predictable sequential integers. This choice mitigates enumeration attacks and aids in distributed data handling across services.
- **Strong Typing with PostgreSQL ENUMs**: Business constraints on categorical fields are strictly enforced at the database level using custom ENUM types (e.g., wallet_type, transaction_type, periodicity_type, forecast_scenario). This natively prevents invalid states rather than relying solely on the application layer validation.
- **JSONB Serialization**: Elements with dynamic structural logic, such as forecast projections (projection_json) and guest report sessions (report_json), leverage PostgreSQL's JSONB binary format. This allows high-performance reads and flexible data structures for analytical features without rigid schema changes.
- **Defensive Constraints**: Critical numerical fields (such as amount in transactions and monthly_amount in plans) are safeguarded with explicit CHECK constraints directly in the DDL to enforce strictly positive values.
- **Data Lifecycle**: Most relational links (e.g., wallet to user, transaction to wallet) enforce ON DELETE CASCADE constraints. This guarantees that when a parent entity is purged (like a user account), all subordinate financial data is automatically expunged, effectively preventing orphaned records.

4 Presentation Logic Layer

The presentation layer of FinTrack is organized around a public entry flow, an authenticated area for registered users, and a guest-only calculator area. The main pages are the following:

- **Home page:** The landing page of the application, where users can choose whether to log in, register, or continue as guest.
- **Login page:** A page for returning users, with an email and password form and error feedback for invalid credentials or missing input.
- **Registration page:** A page for new users, with a form for name, surname, email, and password, plus validation and duplicate-email feedback.
- **Dashboard page:** The main authenticated overview page, showing the user's financial summary and the list of wallets currently associated with the account.
- **Forecasting page:** An authenticated analytical page dedicated to scenario-based financial projections generated from the user's transactions, recurring expenses, and PAC plans.
- **PAC page:** A protected page where the user can create, inspect, update, and delete PAC plans.
- **Guest page:** A public calculator area that allows non-registered users to access the loan, compound-interest, and budget calculators together with their related reports.

4.1 Home Page

The Home page is the public landing page of FinTrack. Its purpose is to present the three main entry points of the system in a simple and immediate way. From this page, the user can choose to authenticate through the Login page, create a new account through the Registration page, or continue without registration by entering the guest calculator area. The page therefore acts as the starting point of the whole navigation flow. It is intentionally lightweight, because its role is not to show financial data but to route the visitor toward the correct experience depending on whether the visitor is already registered or only wants to use the public calculators.

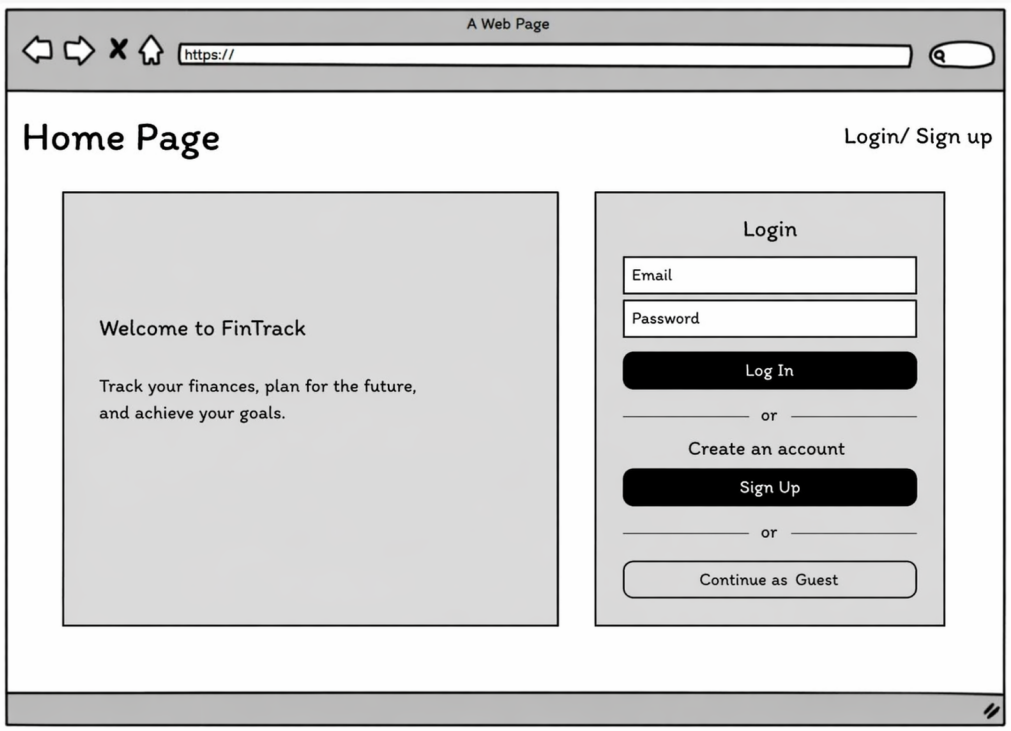


Figure 2: Home Page

4.2 Login Page

The Login page is designed for returning users who want to access the protected area of the application. The interface contains a form with two input fields, one for the email address and one for the password. When the form is submitted, the credentials are sent to the authentication servlet, which validates the input and checks whether the account exists and the password is correct. If the authentication succeeds, the user session is initialized and the user is redirected to the Dashboard page. If the input is incomplete or the credentials are invalid, an error message is shown on the same page. A link to the Registration page is also provided so that a visitor without an account can move directly to the sign-up flow.

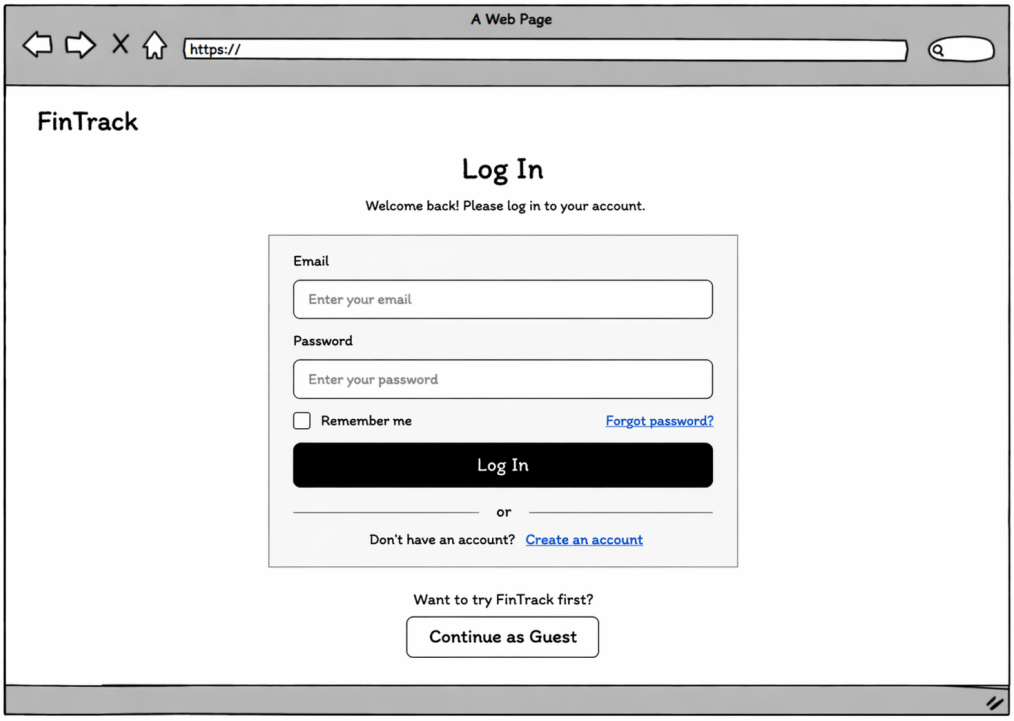


Figure 3: Login Page

4.3 Registration Page

The Registration page allows a new user to create a personal FinTrack account. The page contains a form with the fields required by the application logic: name, surname, email, and password. These values are validated before the account is created, so the page must support the display of feedback messages in case one or more fields are missing or the email address is already associated with another account. After a successful registration, the application immediately opens an authenticated session for the new user and redirects the user to the Dashboard page. In this way, the registration flow is integrated with the main personal area of the system without requiring a second login step. The page also includes a link back to the Login page for users who already have an account.

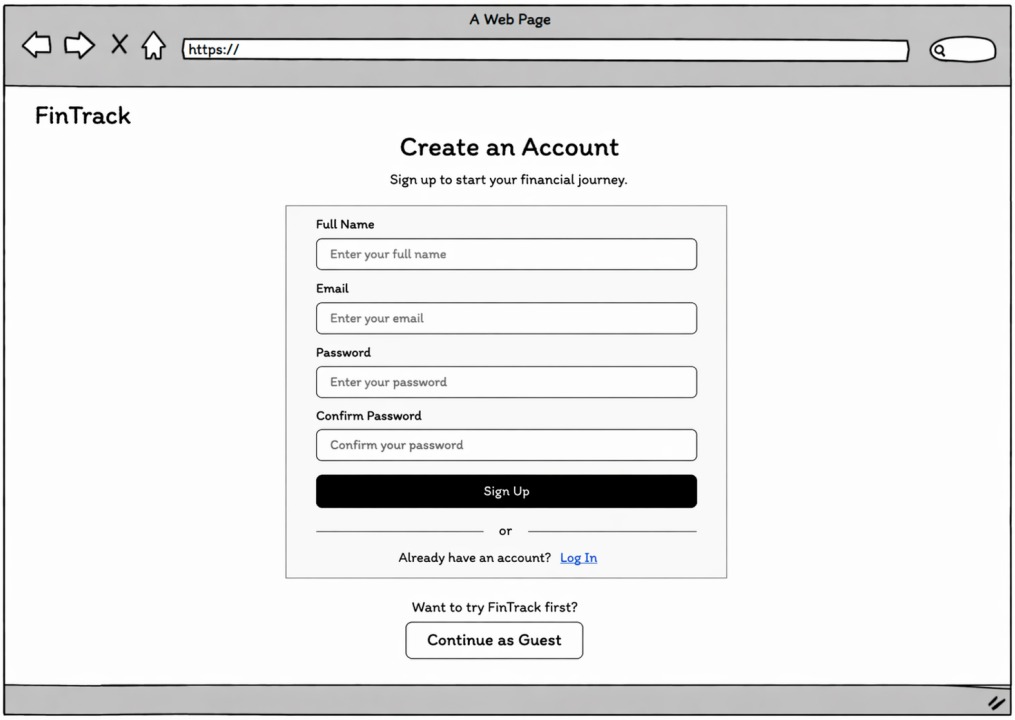


Figure 4: Registration Page

4.4 Dashboard Page

The Dashboard page is the main overview page for authenticated users. At the top, it greets the user by name, confirming that the personal session is active. The page then shows a financial summary containing the main high-level indicators currently produced by the business logic: total equity, year-to-date expenses, and year-to-date savings. Below the summary, the page displays the list of wallets owned by the user. For each wallet, the interface shows the wallet name, wallet type, currency, and current balance. If the user has not created any wallet yet, the page displays a message inviting the user to create the first one. A logout button is also provided so that the user can explicitly terminate the authenticated session.

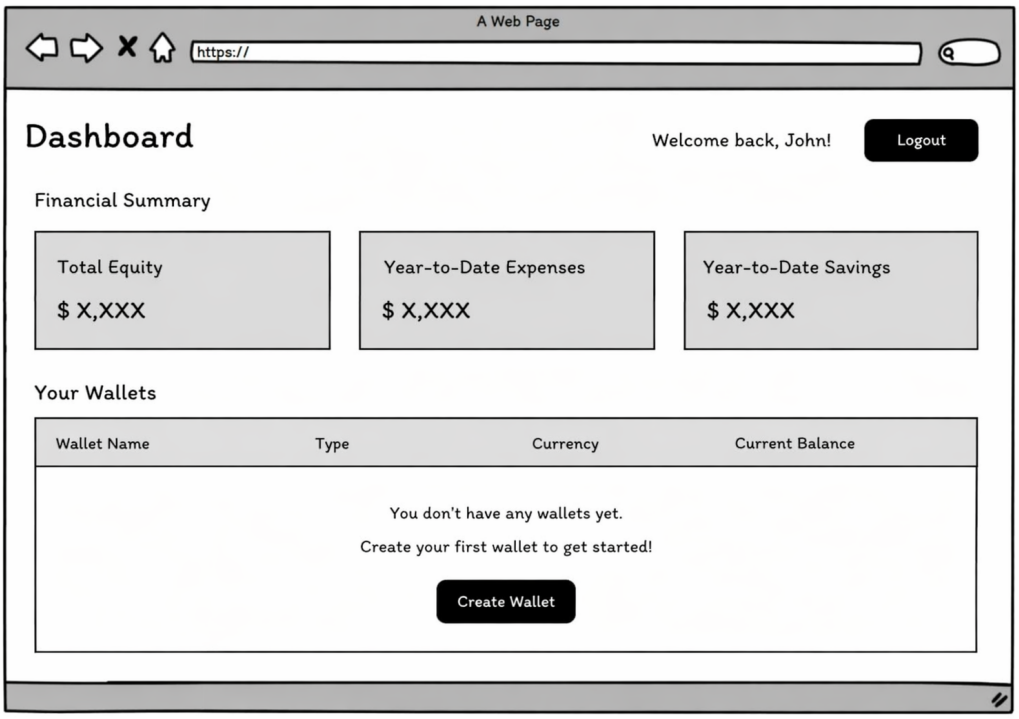


Figure 5: Dashboard Page

4.5 Forecasting Page

The Forecasting page is an authenticated analytical page focused on future financial projections. In the current source code, the forecasting functionality is backed by the `/api/forecast` endpoint, which accepts a scenario and returns a generated projection for the authenticated user. The supported scenarios are `OPTIMISTIC`, `CONSERVATIVE`, and `STRESS_TEST`. From a presentation point of view, the page is meant to let the user choose one of these scenarios and inspect the generated projection. Each forecast is computed over 24 months and includes, for every month, the estimated income, expense, PAC contribution, net flow, and resulting balance. The page therefore provides a visual and tabular summary of how the user's finances may evolve under different assumptions.

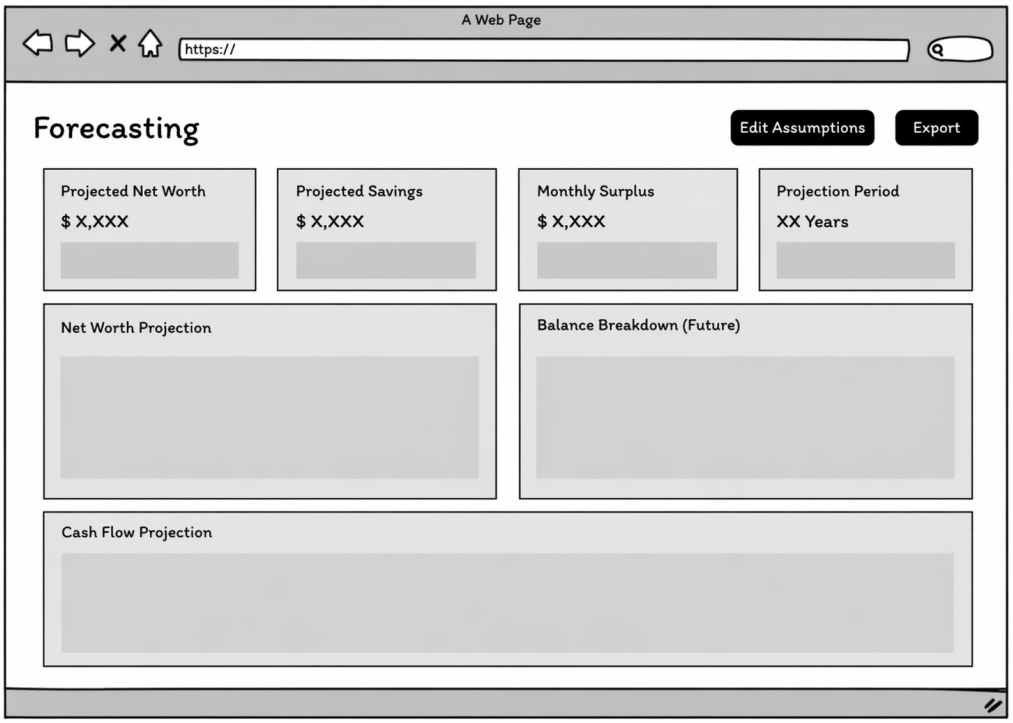


Figure 6: Forecasting Page

4.6 PAC Page

The PAC page is a protected management page dedicated to recurring investment plans. According to the application logic, each PAC plan contains an asset name, a monthly contribution amount, a target amount, a start date, and an active flag. The page must therefore allow the user to visualize the list of plans already stored in the system and to perform the main CRUD operations on them. In particular, the interface supports plan creation, modification, and deletion through the dedicated PAC servlets. The page also shows success or error messages after each operation, for example when a plan is created correctly, when validation fails, or when the user attempts an unauthorized action. This page is important because PAC plans are also reused by the forecasting logic as part of the monthly projection.

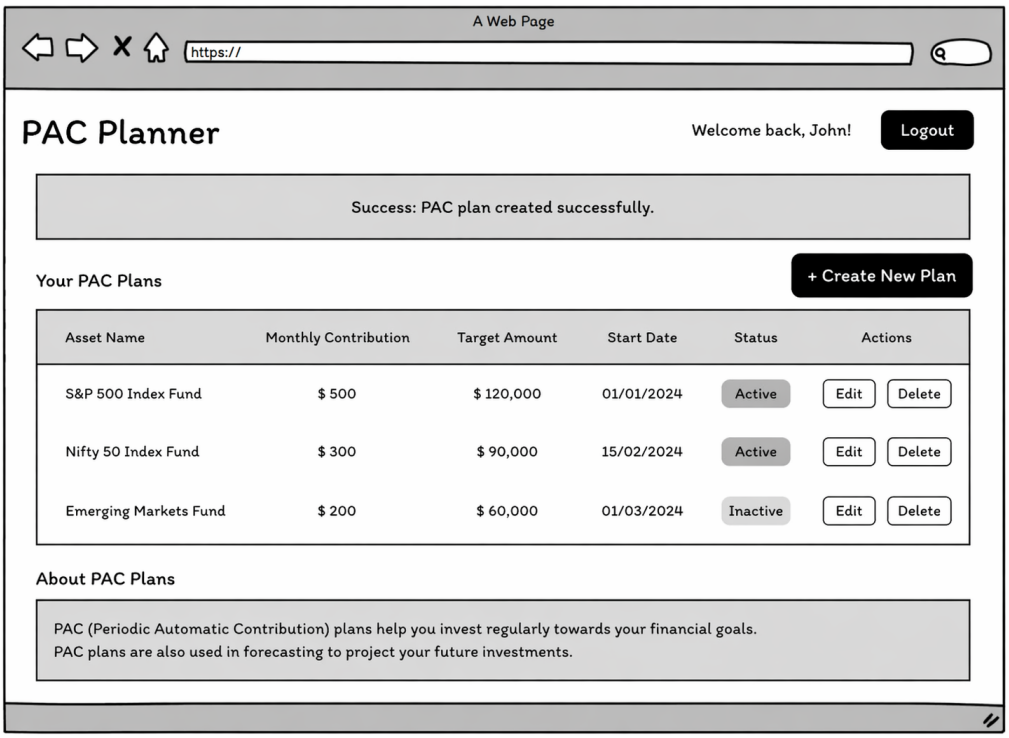


Figure 7: PAC Page

4.7 Guest Page

The Guest page is the public calculator area of FinTrack and is accessible without creating an account. When a user enters this area, the system associates the browser session with a guest token and forwards the request to the calculator page. The interface groups together three independent tools: a loan calculator, a compound-interest calculator, and a budget calculator. The loan calculator asks for principal, annual rate, and duration in months, then produces a report page showing the amortization table month by month. The compound-interest calculator collects the initial capital, monthly contribution, annual rate, and duration in years, then shows the total value reached year by year. The budget calculator lets the user dynamically add and remove income and expense rows, and after submission it generates a report page with total income, total expenses, net balance, and a category-by-category breakdown. The Guest page therefore offers a complete public entry point for trying the financial analysis tools before registration.

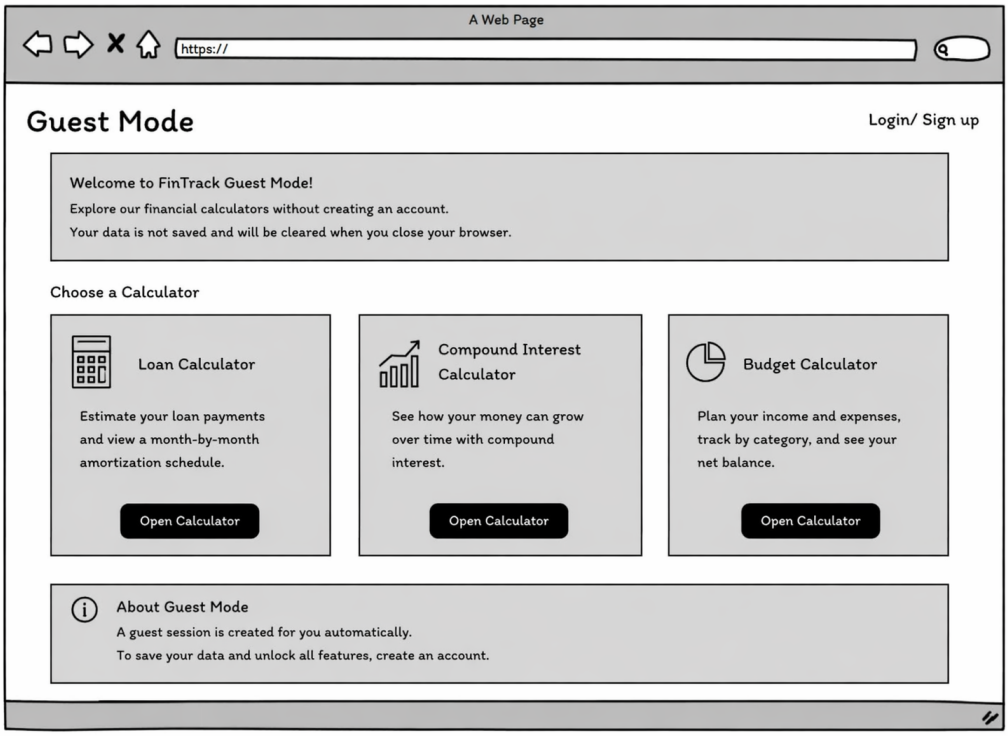


Figure 8: Guest Page

5 Business Logic Layer

5.1 Class Diagram

FinTrack is structured according to a three-tier architecture in which the business logic layer acts as the mediator between the presentation and the data layers. This layer is responsible for all domain-specific rules, input validation, and computational logic of the application. It is composed of service classes, filter classes, model objects, and data access objects, each with a clearly defined responsibility. Service classes never communicate directly with the database; they always delegate persistence to the appropriate DAO, keeping the business rules independent of the underlying storage technology. The following subsections describe each component category in detail.

5.1.1 Servlets

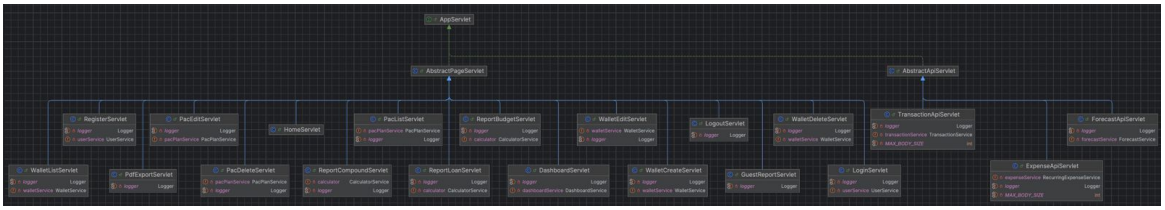


Figure 9: Servlet diagram

The application exposes two categories of servlets: page servlets, which follow the Post/Redirect/Get pattern and produce HTML responses via JSP forwarding, and API servlets, which accept and return JSON and serve AJAX-driven interactions on the client side. Among the page servlets, `LoginServlet` and `RegisterServlet` handle the two authentication entry points. Both accept `POST` requests, delegate the operation to `UserService`, and on success create an authenticated `HttpSession` via `AuthenticationSessionUtil` before redirecting the user to the dashboard. On failure, they redirect back to the originating page with an error code in the query string, which the corresponding `GET` handler of the same servlet reads and translates into a user-facing message attribute before forwarding to the JSP. `LogoutServlet` invalidates the current session and redirects to the login page. `DashboardServlet` loads the user's financial summary via `DashboardService` and forwards the `DashboardSummary` object to the dashboard JSP. `WalletListServlet` loads and displays all wallets;

`WalletCreateServlet`, `WalletEditServlet`, and `WalletDeleteServlet` process the corresponding `POST` requests and redirect with a `success` or `error` parameter. The same PRG pattern is applied symmetrically by `PacListServlet`, `PacCreateServlet`, `PacEditServlet`, and `PacDeleteServlet` for investment plan management. The guest area is served by `GuestReportServlet`, which displays the calculator page, and by three calculator servlets: `ReportLoanServlet`, `ReportCompoundServlet`, and `ReportBudgetServlet`. Each of these parses the submitted form parameters, calls `CalculatorService` to perform the computation, serialises the result to JSON, and persists it into the guest session via `ReportSessionDAO`. On validation failure, they re-forward to the calculator JSP with an error message attribute rather than redirecting, so that the user's input remains visible. `PdfExportServlet` handles PDF downloads for both guest and authenticated users: for guests it validates the URL token against the one stored in the `HttpSession` before generating the file, and for authenticated users it fetches live dashboard data at download time. The three API servlets — `TransactionApiServlet`, `ExpenseApiServlet`, and `ForecastApiServlet` — extend `HttpServlet` and override the standard HTTP method handlers (`doGet`, `doPost`, `doPut`, `doDelete`). Each servlet extracts the resource identifier from the URL path using `getPathInfo()`, reads the JSON request body via a bounded `BufferedReader` (capped at 8 KB to prevent abuse), deserialises it into a `JSONObject`, and delegates processing to the corresponding service class. Errors are always returned as `{"error": "message"}` JSON objects with the appropriate HTTP status code, and a defensive session check provides a 401 response even if `AuthenticationFilter` is somehow bypassed.

5.1.2 Filters

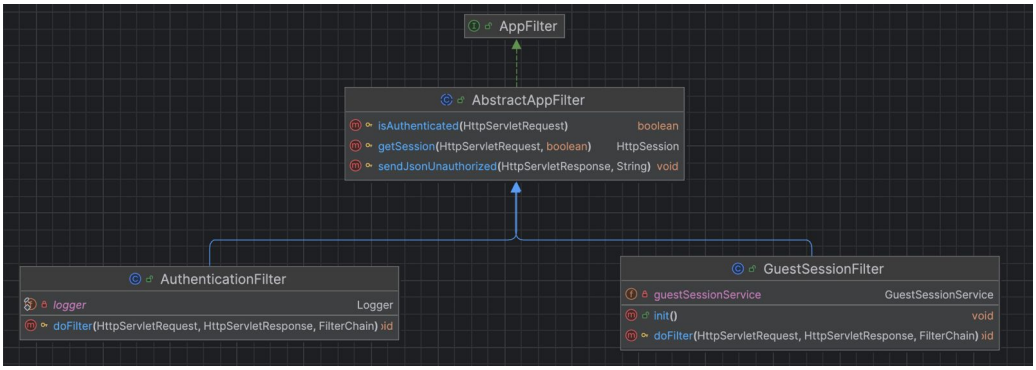


Figure 10: Filter diagram

On our application we have two servlet filters govern access control for the entire application. The first filter is `AuthenticationFilter` and is mapped to all routes that require a registered account: `/dashboard`, `/wallets/*`, `/pac/*`, `/forecast/*`, `/transactions/*`, and `/api/*`. It checks whether the current `HttpSession` contains an `authenticatedUser` attribute. If not, it applies two different rejection strategies depending on the request path: requests to `/api/*` receive a `401 Unauthorized` JSON response (since those callers are JavaScript code and cannot follow a redirect), while all other requests are redirected to `/login`. The last filter is called `GuestSessionFilter` and mapped to the guest calculator routes (`/guest/*`, `/report/loan`, `/report/compound`, `/report/budget`). It ensures that every visitor has an active guest session before reaching the servlet, creating one transparently if needed. It reads the `guestSessionToken` attribute from the `HttpSession`, delegates to `GuestSessionService.ensureGuestSessionExists()`, and stores the returned token back into the session. The service handles both the case where no token exists yet and the case where the token's database row has expired, creating a fresh session in both cases.

5.1.3 Resources

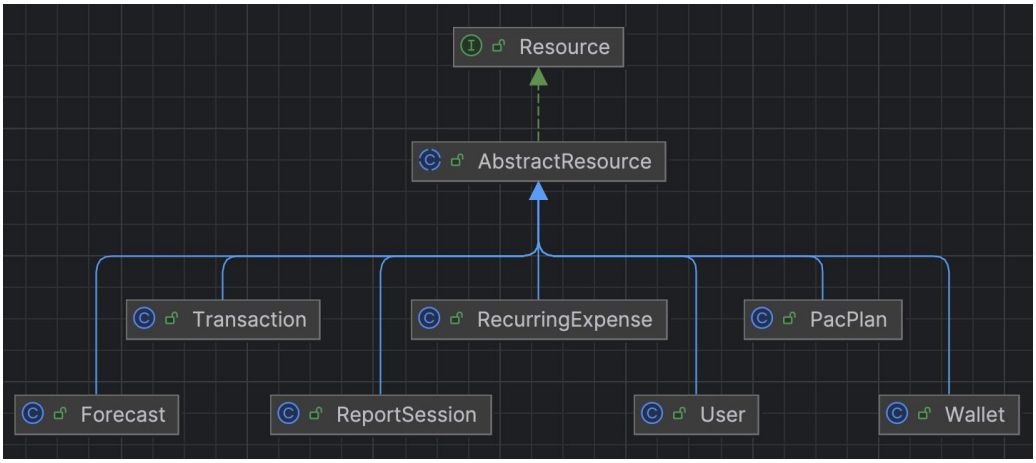


Figure 11: Resources diagram

The model package contains the data transfer objects and domain entities shared across all layers. `User` stores the user's identity and PBKDF2 password hash. `Wallet` holds the name, type, and currency of a financial ac-

count. `Transaction` records a single financial movement, storing the absolute amount alongside an explicit `TransactionType` enum (`INCOME` or `EXPENSE`). `RecurringExpense` describes a periodic fixed cost linked to a wallet, with a `Periodicity` enum (`MONTHLY`, `QUARTERLY`, `YEARLY`) and an active/inactive flag. `PacPlan` holds a PAC investment plan with a monthly contribution and a target amount. Several read-only value objects are produced by the analytics layer. `WalletSummary` carries a computed balance alongside the wallet metadata. `DashboardStats` is a Java record holding per-currency equity, YTD expenses, and YTD savings. `DashboardSummary` wraps both collections into a single object for the presentation layer. `Forecast` stores the scenario name and the 24-entry projection JSON array. The guest area uses three result objects specific to `CalculatorService`: `AmortizationRow` (one row per month of the loan schedule), `CompoundResult` (one entry per year of the compound interest projection), and `BudgetResult` (income and expense totals with per-category breakdowns). `ReportSession` holds the guest's accumulated JSON payload alongside its expiry timestamp.

5.1.4 Data Access

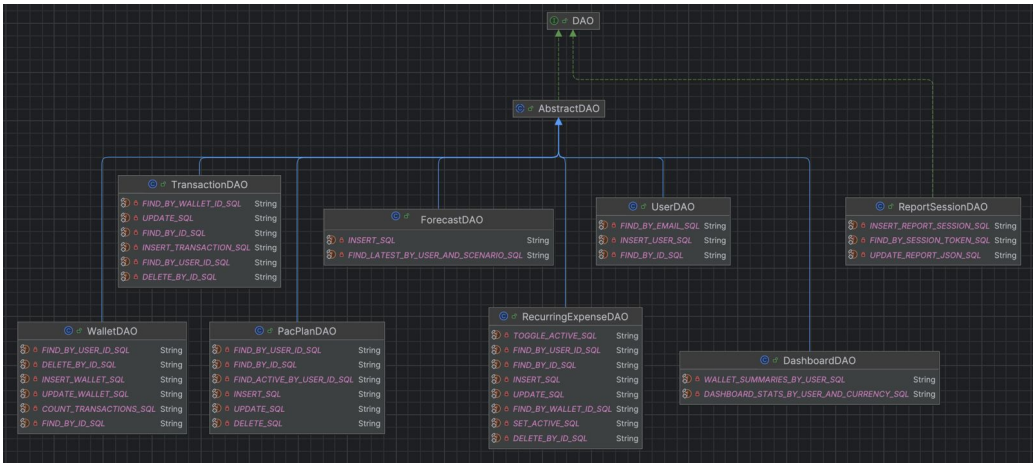


Figure 12: DAO diagram

Each service class depends on one or more DAO classes that encapsulate all database interaction. Every DAO opens connections via a shared `DBConnection` utility and uses `try-with-resources` to ensure that connections, statements, and result sets are always closed, even on exceptional paths. SQL queries are held in `private static final String` constants and executed exclusively through `PreparedStatement`, eliminating any risk of SQL injection. `UserDAO` provides lookup by email and user creation. `WalletDAO` supports full CRUD operations and exposes a `countTransactions()` method used by the service to enforce the no-deletion-with-transactions rule. `TransactionDAO` adds a `findByUserId()` method used by `ForecastService` to reconstruct the historical balance. `RecurringExpenseDAO` provides both a per-wallet and a per-user lookup to support the expense management page and the forecast computation respectively. `PacPlanDAO` exposes a `findActiveByUserId()` method for the same reason. `DashboardDAO` executes two aggregation queries: one that computes per-wallet running balances via conditional `SUM(CASE WHEN ...)` expressions, and one that produces per-currency YTD statistics using the same technique filtered by the current year. `ForecastDAO` stores projections and retrieves the most recent one per user and scenario via `ORDER BY created_at DESC LIMIT 1`. `ReportSessionDAO` manages guest session rows, including creation with an expiry timestamp and JSON update; the expiry check is enforced at the query level by appending `AND expires_at > CURRENT_TIMESTAMP` to the lookup condition.

5.1.5 REST Resources and Routing

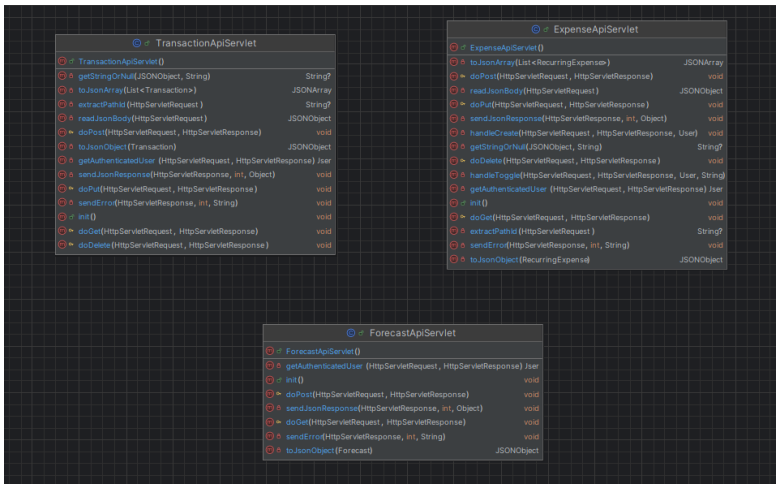


Figure 13: Api diagram

The application exposes its REST interface under the `/api/` prefix, which is protected uniformly by `AuthenticationFilter`. Resources are addressed with RESTful URL patterns and method semantics. `/api/transactions/*` is handled entirely by `TransactionApiServlet`. The path segment after the prefix, extracted via `getPathInfo()`, identifies the individual transaction for `PUT` and `DELETE` operations, while `GET` uses a `walletId` query parameter to return all transactions belonging to a wallet. `POST` creates a new transaction from a JSON body containing the wallet identifier, amount, category, date, and an optional note. `/api/expenses/*` follows the same structural pattern via `ExpenseApiServlet`, with the addition of a sub-resource path: `/api/expenses/{id}/toggle` accepts a `POST` request to flip the active status of a recurring expense without requiring a full update payload. `/api/forecast` is served by `ForecastApiServlet`. A `POST` request with a `scenario` query parameter triggers a full recomputation and stores the result; a `GET` request retrieves the latest stored projection for the same scenario. The three valid scenario values — `OPTIMISTIC`, `CONSERVATIVE`, and `STRESS_TEST` — are resolved via `ForecastScenario.valueOf()`, and an `IllegalArgumentException` from that call is mapped to a `400 Bad Request` response.

5.2 Sequence Diagram

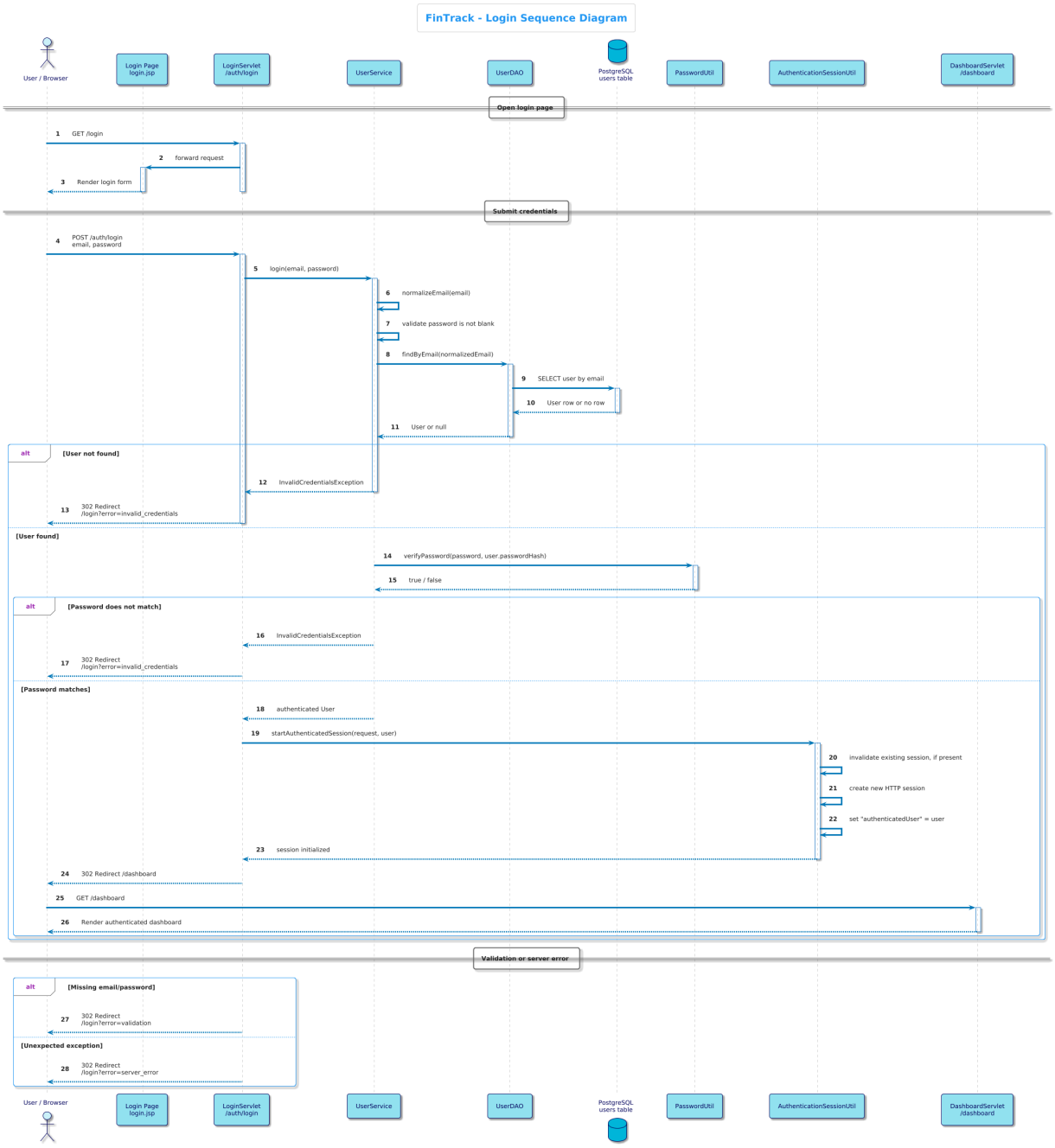


Figure 14: Login Sequence Diagram

The diagram illustrates the login flow implemented in FinTrack, from opening the login page to creating an authenticated HTTP session. The main events are as follows:

1. **Login Page Rendering:**
   The process starts when the browser sends a `GET /login` request. The request is handled by `LoginServlet`, which forwards the request to the JSP login page. The page renders the form where the user can enter an email address and password.

2. **Login Request Processing:**
   When the form is submitted, the browser sends a `POST /auth/login` request to `LoginServlet`. The servlet extracts the credentials from the request and delegates the authentication logic to `UserService`. The service performs the core checks by:

   - Normalizing the email address and validating that the password is not blank.
   - Loading the corresponding user record through `UserDAO`.
   - Querying the PostgreSQL `users` table for a matching email address.
   - Verifying the submitted password against the stored hash through `PasswordUtil`.

3. **Outcome Handling:**
   The final outcome depends on the validation and password verification result:

   - **Missing or invalid input:** The servlet redirects the browser to `/login?error=validation`.
   - **Wrong credentials:** If no user is found, or if the password does not match the stored hash, `UserService` raises an `InvalidCredentialsException`; the servlet redirects to `/login?error=invalid_credentials`.
   - **Successful login:** If authentication succeeds, `LoginServlet` calls `AuthenticationSessionUtil` to invalidate any existing session, create a new HTTP session, and store the authenticated `User` object under the `authenticatedUser` session attribute. The browser is then redirected to `/dashboard`.
   - **Unexpected server error:** If an internal exception occurs, the servlet redirects to `/login?error=server_error`.

5.3 REST API Summary

The application exposes two categories of endpoints: Servlet/JSP endpoints using the Post/Redirect/Get pattern for page-based interactions, and REST/JSON endpoints for AJAX-driven features. Both categories are listed below.

Servlet/JSP Endpoints (PRG Pattern)

URI	Method	Description	Filter
`/`	GET	Home page.	–
`/login`	GET	Display login page.	–
`/auth/login`	POST	Authenticate user; redirect to `/dashboard`.	–
`/register`	GET	Display registration page.	–
`/auth/register`	POST	Create new user; redirect to `/dashboard`.	–
`/auth/logout`	POST/GET	Invalidate session; redirect to `/login`.	–
`/dashboard`	GET	Dashboard with financial summary.	Auth
`/wallets`	GET	List all wallets for the user.	Auth
`/wallets/create`	POST	Create a new wallet; redirect to `/wallets`.	Auth
`/wallets/edit`	POST	Update wallet; redirect to `/wallets`.	Auth

/wallets/delete	POST	Delete wallet; redirect to /wallets.	Auth
/pac	GET	List all PAC plans for the user.	Auth
/pac/create	POST	Create a new PAC plan; redirect to /pac.	Auth
/pac/edit	POST	Update PAC plan; redirect to /pac.	Auth
/pac/delete	POST	Delete PAC plan; redirect to /pac.	Auth
/guest/report	GET	Guest calculator page.	Guest
/report/loan	POST	Compute loan amortization schedule.	Guest
/report/compound	POST	Compute compound interest projection.	Guest
/report/budget	POST	Compute budget breakdown.	Guest
/report/export	GET	Export report as PDF.	–

Table 2: Servlet/JSP endpoints. "Auth" = AuthenticationFilter (redirects to /login). "Guest" = GuestSessionFilter (initializes guest token).

REST/JSON API Endpoints

URI	Method	Description	Filter
/api/transactions?walletId={walletId}	GET	List all transactions for a wallet.	Auth
/api/transactions	POST	Create a new transaction.	Auth
/api/transactions/{transactionId}	PUT	Update a transaction.	Auth
/api/transactions/{transactionId}	DELETE	Delete a transaction.	Auth
/api/expenses	GET	List all recurring expenses for the user.	Auth
/api/expenses	POST	Create a new recurring expense.	Auth
/api/expenses/{expenseId}	PUT	Update a recurring expense.	Auth
/api/expenses/{expenseId}	DELETE	Delete a recurring expense.	Auth
/api/expenses/{expenseId}/toggle	POST	Toggle active/inactive status.	Auth
/api/forecast?scenario={scenario}	POST	Compute 24-month projection.	Auth
/api/forecast?scenario={scenario}	GET	Retrieve latest stored projection.	Auth

Table 3: REST/JSON API endpoints. All /api/* routes are protected by AuthenticationFilter, which returns a JSON 401 response for unauthenticated requests instead of redirecting.

5.4 REST Error Codes

All REST API endpoints return errors as JSON objects in the format {"error": "message"}. The following table summarizes the HTTP status codes used across the API and their meaning.

Error Code	HTTP Status	Description

400	Bad Request	Malformed JSON body, missing required fields, invalid UUID format, invalid amount or date format, empty request body, oversized request body (¿8KB), invalid scenario value, or blank required parameters.
401	Unauthorized	Authentication required. Returned by `AuthenticationFilter` for unauthenticated `/api/*` requests, or by the servlet-level defensive check if the session has expired.
403	Forbidden	The authenticated user does not own the requested resource (e.g., attempting to modify another user's wallet or transaction).
404	Not Found	The requested resource does not exist (e.g., no forecast computed yet for the given scenario).
500	Internal Server Error	An unexpected server error occurred. Internal details are never exposed; the response contains only a generic error message.

Table 4: HTTP status codes used by the REST API.

5.5 REST API Details

This section documents the REST/JSON API endpoints and the Servlet/JSP endpoints. REST endpoints return JSON responses with appropriate HTTP status codes. Servlet/JSP endpoints follow the Post/Redirect/Get pattern and forward to JSP pages for rendering.

5.5.1 User Registration

Registers a new user. The password is hashed using PBKDF2 before storage.

- **URL:** `/auth/register`
- **Method:** `POST`
- **Data Parameters (form):**
  - `name` = {string}
  - `surname` = {string}
  - `email` = {string}
  - `password` = {string}
- **Success Response:**
  - HTTP 302 redirect to `/dashboard`; session created with authenticated user.
- **Error Responses:**
  - Redirect to `/register?error=email_exists` if the email is already registered.
  - Redirect to `/register?error=validation` if required fields are missing.
  - Redirect to `/register?error=server_error` on internal failure.

5.5.2 User Login

Authenticates an existing user by verifying email and password against the stored hash.

- **URL:** `/auth/login`
- **Method:** `POST`
- **Data Parameters (form):**
  - `email` = {string}
  - `password` = {string}
- **Success Response:**
  - HTTP 302 redirect to `/dashboard`; session created with authenticated user.
- **Error Responses:**
  - Redirect to `/login?error=invalid_credentials` if credentials are wrong.
  - Redirect to `/login?error=validation` if fields are missing.
  - Redirect to `/login?error=server_error` on internal failure.

5.5.3 User Logout

Invalidates the current session and redirects to the login page.

- **URL:** `/auth/logout`
- **Method:** `POST` or `GET`
- **Data Parameters:** None
- **Success Response:**
  - HTTP 302 redirect to `/login`.

5.5.4 List Wallets

Returns all wallets belonging to the authenticated user, forwarded to a JSP page for rendering.

- **URL:** `/wallets`
- **Method:** `GET`
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with the wallet list page rendered via JSP.
- **Error Responses:**
  - Redirect to `/login` if unauthenticated.

5.5.5 Create Wallet

Creates a new wallet for the authenticated user. Currency is normalized to uppercase and validated as a 3-letter alphabetic code. All wallets under one account must use the same currency.

- **URL:** `/wallets/create`
- **Method:** `POST`
- **Data Parameters (form):**
  - `name` = {string}
  - `type` = {string} (CASH, BANK_ACCOUNT, CREDIT_CARD, or INVESTMENT)
  - `currency` = {string} (3-letter code, e.g., EUR)
- **Success Response:**
  - Redirect to `/wallets?success=created`.
- **Error Responses:**
  - Redirect to `/wallets?error=validation` if fields are invalid.
  - Redirect to `/wallets?error=currency_mismatch` if currency differs from existing wallets.
  - Redirect to `/wallets?error=server_error` on internal failure.

5.5.6 Edit Wallet

Updates wallet name, type, or currency. Ownership is verified before mutation.

- **URL:** `/wallets/edit`
- **Method:** `POST`
- **Data Parameters (form):**
  - `walletId` = {UUID}
  - `name` = {string}
  - `type` = {string}
  - `currency` = {string}
- **Success Response:**
  - Redirect to `/wallets?success=updated`.
- **Error Responses:**
  - Redirect to `/wallets?error=validation` for invalid input or malformed UUID.
  - Redirect to `/wallets?error=not_found` if wallet does not exist.
  - Redirect to `/wallets?error=currency_mismatch` if currency differs from other wallets.
  - Redirect to `/wallets?error=unauthorized` if wallet belongs to another user.

5.5.7 Delete Wallet

Deletes a wallet. Rejected if the wallet contains linked transactions.

- **URL:** `/wallets/delete`
- **Method:** `POST`
- **Data Parameters (form):**
  - `walletId` = {UUID}
- **Success Response:**
  - Redirect to `/wallets?success=deleted`.
- **Error Responses:**
  - Redirect to `/wallets?error=validation` for missing or malformed UUID.
  - Redirect to `/wallets?error=not_found` if wallet does not exist.
  - Redirect to `/wallets?error=has_transactions` if wallet has linked transactions.
  - Redirect to `/wallets?error=unauthorized` if wallet belongs to another user.

5.5.8 List Transactions

Retrieves all transactions for a given wallet as JSON, ordered by transaction date descending. Wallet ownership is verified.

- **URL:** `/api/transactions?walletId={walletId}`
- **Method:** `GET`
- **URL Parameters:**
  - `walletId` = {UUID} (required)
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with a JSON array of transaction objects.
- **Error Responses:**
  - HTTP 400 if `walletId` is missing or has an invalid UUID format.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the wallet does not belong to the authenticated user.

5.5.9 Create Transaction

Creates a new transaction within a wallet. The transaction type (income or expense) is resolved automatically from the sign of the amount: positive values are treated as income, negative values as expenses. The amount is stored as an absolute value scaled to two decimal places.

- **URL:** `/api/transactions`
- **Method:** `POST`
- **Data Parameters (JSON body):**
  - `walletId` = {UUID} (required)
  - `amount` = {string} (required, non-zero numeric value)
  - `category` = {string} (required, max 80 characters)
  - `date` = {string} (required, format YYYY-MM-DD)
  - `note` = {string} (optional, blank values normalized to null)
- **Success Response:**
  - HTTP 201 with the created transaction as a JSON object.
- **Error Responses:**
  - HTTP 400 if the request body is malformed, empty, oversized (¿8KB), or contains invalid field values.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the wallet does not belong to the authenticated user.

5.5.10 Update Transaction

Updates an existing transaction. Ownership is verified through the transaction's parent wallet.

- **URL:** `/api/transactions/{transactionId}`
- **Method:** `PUT`
- **URL Parameters:**
  - `transactionId` in path (UUID)
- **Data Parameters (JSON body):**
  - `amount` = {string} (required)
  - `category` = {string} (required)
  - `date` = {string} (required, format YYYY-MM-DD)
  - `note` = {string} (optional)
- **Success Response:**
  - HTTP 200 with the updated transaction as a JSON object.
- **Error Responses:**
  - HTTP 400 if the transaction ID is invalid, the body is malformed, or field values are invalid.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the transaction's wallet does not belong to the authenticated user.

5.5.11 Delete Transaction

Deletes an existing transaction. Ownership is verified through the transaction's parent wallet.

- **URL:** `/api/transactions/{transactionId}`
- **Method:** `DELETE`
- **URL Parameters:**
  - `transactionId` in path (UUID)
- **Data Parameters:** None
- **Success Response:**
  - HTTP 204 No Content.
- **Error Responses:**
  - HTTP 400 if the transaction ID is missing or has an invalid format.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the transaction's wallet does not belong to the authenticated user.

5.5.12 List Recurring Expenses

Retrieves all recurring expenses for the authenticated user as JSON.

- **URL:** `/api/expenses`
- **Method:** `GET`
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with a JSON array of recurring expense objects.
- **Error Responses:**
  - HTTP 401 if the user is not authenticated.
  - HTTP 500 on internal failure.

5.5.13 Create Recurring Expense

Creates a new recurring expense linked to a wallet owned by the authenticated user.

- **URL:** `/api/expenses`
- **Method:** `POST`
- **Data Parameters (JSON body):**
  - `walletId` = {UUID} (required)
  - `label` = {string} (required)
  - `amount` = {string} (required, positive numeric value)

  - `periodicity` = {string} (required: MONTHLY, QUARTERLY, or YEARLY)
  - `nextDue` = {string} (required, format YYYY-MM-DD)
- **Success Response:**
  - HTTP 201 with the created recurring expense as a JSON object.
- **Error Responses:**
  - HTTP 400 for malformed JSON or invalid field values.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the wallet does not belong to the authenticated user.

5.5.14 Update Recurring Expense

Updates an existing recurring expense. Ownership is verified through the expense's parent wallet.

- **URL:** `/api/expenses/{expenseId}`
- **Method:** `PUT`
- **URL Parameters:**
  - `expenseId` in path (UUID)
- **Data Parameters (JSON body):**
  - `label` = {string} (required)
  - `amount` = {string} (required)
  - `periodicity` = {string} (required)
  - `nextDue` = {string} (required, format YYYY-MM-DD)
- **Success Response:**
  - HTTP 200 with the updated recurring expense as a JSON object.
- **Error Responses:**
  - HTTP 400 for malformed JSON, invalid UUID, or invalid field values.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the expense's wallet does not belong to the authenticated user.
  - HTTP 404 if the recurring expense does not exist.

5.5.15 Delete Recurring Expense

Deletes an existing recurring expense. Ownership is verified.

- **URL:** `/api/expenses/{expenseId}`
- **Method:** `DELETE`
- **URL Parameters:**
  - `expenseId` in path (UUID)

- **Data Parameters:** None
- **Success Response:**
  - HTTP 204 No Content.
- **Error Responses:**
  - HTTP 400 if the expense ID is missing or invalid.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the expense's wallet does not belong to the authenticated user.
  - HTTP 404 if the recurring expense does not exist.

5.5.16 Toggle Recurring Expense Active Status

Toggles a recurring expense between active and inactive. Ownership is verified.

- **URL:** `/api/expenses/{expenseId}/toggle`
- **Method:** `POST`
- **URL Parameters:**
  - `expenseId` in path (UUID)
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with the updated recurring expense as a JSON object.
- **Error Responses:**
  - HTTP 400 if the expense ID is invalid.
  - HTTP 401 if the user is not authenticated.
  - HTTP 403 if the expense's wallet does not belong to the authenticated user.
  - HTTP 404 if the recurring expense does not exist.

5.5.17 List PAC Plans

Returns all PAC plans belonging to the authenticated user, forwarded to a JSP page.

- **URL:** `/pac`
- **Method:** `GET`
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with the PAC plan list page rendered via JSP.
- **Error Responses:**
  - Redirect to `/login` if unauthenticated.

5.5.18 Create PAC Plan

Creates a new PAC (DCA) investment plan for the authenticated user.

- **URL:** `/pac/create`
- **Method:** `POST`
- **Data Parameters (form):**
  - `assetName` = {string} (max 120 characters)
  - `monthlyAmount` = {string} (positive numeric value)
  - `targetAmount` = {string} (positive numeric value)
  - `startDate` = {string} (format YYYY-MM-DD)
- **Success Response:**
  - Redirect to `/pac?success=created`.
- **Error Responses:**
  - Redirect to `/pac?error=validation` for invalid input.
  - Redirect to `/pac?error=server_error` on internal failure.

5.5.19 Edit PAC Plan

Updates an existing PAC plan. Ownership is verified.

- **URL:** `/pac/edit`
- **Method:** `POST`
- **Data Parameters (form):**
  - `planId` = {UUID}
  - `assetName` = {string}
  - `monthlyAmount` = {string}
  - `targetAmount` = {string}
  - `startDate` = {string}
  - `active` = {string} ("true" or "false")
- **Success Response:**
  - Redirect to `/pac?success=updated`.
- **Error Responses:**
  - Redirect to `/pac?error=validation` for invalid input or malformed UUID.
  - Redirect to `/pac?error=not_found` if plan does not exist.
  - Redirect to `/pac?error=unauthorized` if plan belongs to another user.

5.5.20 Delete PAC Plan

Deletes an existing PAC plan. Ownership is verified.

- **URL:** `/pac/delete`
- **Method:** `POST`
- **Data Parameters (form):**
  - `planId` = {UUID}
- **Success Response:**
  - Redirect to `/pac?success=deleted`.
- **Error Responses:**
  - Redirect to `/pac?error=validation` for missing or malformed UUID.
  - Redirect to `/pac?error=not_found` if plan does not exist.
  - Redirect to `/pac?error=unauthorized` if plan belongs to another user.

5.5.21 Compute Forecast

Computes a 24-month financial projection for the authenticated user under the specified scenario and stores the result as JSONB in the `forecasts` table. The projection is based on: current wallet balances, the 3-month average of income and expenses (with adaptive windowing for newer users), active recurring expenses normalized to monthly equivalents, and active PAC plan contributions. All wallets must use the same currency.

- **URL:** `/api/forecast?scenario={scenario}`
- **Method:** `POST`
- **URL Parameters:**
  - `scenario` = {string} (required, one of: `OPTIMISTIC`, `CONSERVATIVE`, `STRESS_TEST`)
- **Data Parameters:** None
- **Success Response:**
  - HTTP 201 with a JSON object containing:
    - `id`: the forecast UUID
    - `scenario`: the scenario name
    - `projection`: a JSON array of 24 monthly entries, each containing `month`, `income`, `expense`, `pacContribution`, `netFlow`, `balance`, and `currency`
    - `createdAt`: the computation timestamp
- **Error Responses:**
  - HTTP 400 if the scenario parameter is missing or invalid.
  - HTTP 400 if wallets use mixed currencies.
  - HTTP 401 if the user is not authenticated.

5.5.22 Retrieve Latest Forecast

Retrieves the most recently computed forecast for the authenticated user and the specified scenario.

- **URL:** `/api/forecast?scenario={scenario}`
- **Method:** `GET`
- **URL Parameters:**
  - `scenario` = {string} (required, one of: `OPTIMISTIC`, `CONSERVATIVE`, `STRESS_TEST`)
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with the forecast JSON object (same structure as the compute response).
- **Error Responses:**
  - HTTP 400 if the scenario parameter is missing or invalid.
  - HTTP 401 if the user is not authenticated.
  - HTTP 404 if no forecast has been computed yet for the given scenario.

5.5.23 Guest Report Page

Displays the guest calculator page with options for loan amortization, compound interest, and budget analysis.

- **URL:** `/guest/report`
- **Method:** `GET`
- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with the calculator page rendered via JSP.

5.5.24 Compute Loan Amortization

Calculates a loan amortization schedule and stores the result in the guest session's report data.

- **URL:** `/report/loan`
- **Method:** `POST`
- **Data Parameters (form):**
  - `principal` = {number} (loan amount)
  - `annualRate` = {number} (annual interest rate)
  - `months` = {integer} (repayment period in months)
- **Success Response:**
  - Redirect to `/guest/report` with results stored in the guest session.
- **Error Responses:**
  - Redirect to `/guest/report?error=validation` for invalid input.

5.5.25 Compute Compound Interest

Calculates a compound interest projection and stores the result in the guest session's report data.

- **URL:** `/report/compound`
- **Method:** `POST`
- **Data Parameters (form):**
  - `initialCapital` = {number} (starting amount)
  - `monthlyContribution` = {number} (monthly deposit)
  - `annualRate` = {number} (annual interest rate)
  - `years` = {integer} (investment period in years)
- **Success Response:**
  - Redirect to `/guest/report` with results stored in the guest session.
- **Error Responses:**
  - Redirect to `/guest/report?error=validation` for invalid input.

5.5.26 Compute Budget Breakdown

Calculates income vs. expense totals with categorized breakdowns and stores the result in the guest session.

- **URL:** `/report/budget`
- **Method:** `POST`
- **Data Parameters (form):**
  - `incomeCategory[]` = {string[]} (array of income category names)
  - `incomeAmount[]` = {number[]} (array of income amounts)
  - `expenseCategory[]` = {string[]} (array of expense category names)
  - `expenseAmount[]` = {number[]} (array of expense amounts)
- **Success Response:**
  - Redirect to `/guest/report` with results stored in the guest session.
- **Error Responses:**
  - Redirect to `/guest/report?error=validation` for invalid input.

5.5.27 Export Report as PDF

Exports the accumulated guest report data as a downloadable PDF file.

- **URL:** `/report/export?token={sessionToken}`
- **Method:** `GET`
- **URL Parameters:**

  - `token` = {UUID} (the guest session token)

- **Data Parameters:** None
- **Success Response:**
  - HTTP 200 with `Content-Type: application/pdf` and the PDF file as the response body.
- **Error Responses:**
  - Redirect to `/guest/report?error=no_data` if no report data exists.
  - HTTP 403 if the token does not match the current session.

6 Group Members Contribution

Alessandro Perin Architected and implemented the core Data Logic Layer, including the PostgreSQL database schema (`init.sql`) with advanced functionalities such as UUIDs, ENUMs, JSONB, and defensive DDL constraints. Developed the fundamental DAO layer (`WalletDAO`, `TransactionDAO`, `RecurringExpenseDAO`) and the comprehensive REST API backend for the Recurring Expenses feature. This included building the Service logic with strict ownership validation, custom exception handling, and an extensive suite of integration tests. Finally, drafted the LaTeX documentation relative to the Data Logic Layer and the Entity-Relationship structures.

Rajmonda Bardhi Designed and implemented the Dashboard Aggregation Service. Built the `DashboardDAO` with optimized SQL queries to compute per-wallet balances and aggregate statistics (total equity, year-to-date expenses, and year-to-date savings) grouped by currency. Developed the `DashboardService` to handle data retrieval and create the `DashboardSummary` response object. Created the `DashboardServlet` handling authenticated GET requests, and the corresponding JSP view. Defined the model classes `DashboardStats`, `DashboardSummary`, and `WalletSummary`. Added additional query methods to `TransactionDAO` and wrote unit and integration tests for the dashboard layer. Finally, wrote the Objectives section of the LaTeX documentation, describing the system goals and the rationale behind each feature.

Meviola Karriqi Collaborated with the team on the initial project design on the Miro board, which included the first draft of the database schema (later refined by the team). Wrote the Trello tickets and helped divide the work across team members throughout the project. On the implementation side, developed the Wallets feature (Servlet/JSP with PRG), the Transactions REST/JSON API, and the PAC plans feature. Added `java.util.logging` across the servlets and the `AuthenticationFilter` to trace errors and security-relevant events. Wrote the Main Functionalities, REST API Summary, REST API Details, and REST Error Codes sections of this LaTeX documentation.

Danil Smirnov Designed and implemented the user authentication flow, with particular focus on the registration and login functionalities. Developed the server-side logic for account creation and credential validation through components such as `LoginServlet`, `RegisterServlet`, `UserService`, and `UserDAO`, and connected the login and registration pages to the backend workflow. Defined the initial domain model classes used across the application, including `User`, `Wallet`, and `Transaction`. Also contributed to the initial setup of page access control filters, such as `AuthenticationFilter` and `GuestSessionFilter`, to separate protected pages from guest-only pages. For the report, also prepared the sequence diagram and the Presentation Logic Layer section.

Giacomo Masiero Designed and implemented the complete guest calculator feature. Developed `CalculatorService` with three financial calculators (loan amortization,compound interest, and budget analysis) and the corresponding result model classes(`AmortizationRow`, `CompoundResult`, `BudgetResult`). Implemented the

three calculator servlets (`ReportLoanServlet`, `ReportCompoundServlet`,`ReportBudgetServlet`), handling JSON serialisation of each computation result and its persistence into the guest session via `ReportSessionDAO`. Built `PdfReportService` using Apache PDFBox to generate downloadable PDF reports for both guest and authenticated users. Created all JSP views in the `calculator` folder and produced the Class Diagram of the Business Logic Layer section of the documentation.